Data Security and Privacy Plan

> **State law:** New York Education Law § 2-d and the Commissioner's regulations at 8 NYCRR Part 121 require every third-party contractor that receives student data, or teacher or principal data, from a New York educational agency to maintain a data security and privacy plan that the agency accepts (§ 121.6). The plan's required elements are followed section by section below. **SDPC NDPA:** TEC's multi-state NDPA (New York Exhibit G, paragraph 4) incorporates the provider's plan by its URL in Exhibit K and requires that it, "at a minimum": (a) implements applicable state, federal, and local requirements; (b) has operational technical safeguards and controls; (c) complies with the district's Parents' Bill of Rights; (d) requires training of employees, assignees, and subprocessors with access; (e) ensures subprocessors protect the data; (f) specifies how incidents are managed with prompt notice; and (g) addresses return, deletion, and destruction. TEC's 10/29 request: "A privacy policy is sufficient if it describes equivalent data security practices." **Drafting choice:** Every commitment below is drawn from Appendix A and Attachment 1 of the Agreement, so the plan and the agreement say the same thing. Bracketed items need a name, a date, or a confirmation from CHSS before publication (Decisions O3, O4, O5, O18, O20). **Needs CHSS confirmation:** Draft for CHSS review. This is not CHSS's published plan. Before it is posted at a CHSS URL and cited in Exhibit K, the technology office confirms every statement is true today or re-tenses it with a date.

Center for High School Success, a program of Stand for Children Leadership Center, Inc.
Effective date: **Pending: effective date** · Owner: **Pending, Jonah: Privacy Officer name (O8)** · Reviewed annually · Published at: **Pending, Emily: CHSS URL (O18)**

This plan describes how the Center for High School Success (CHSS) protects the personally identifiable information it receives from school districts and other local education agencies (each, an "LEA") to provide ninth grade success coaching and the CHSS Navigator platform. It applies to student data, to data about LEA staff, and to data created in CHSS's services, from the time CHSS receives it until it is returned or destroyed. It supplements, and does not replace, CHSS's agreement with each LEA; where an LEA's agreement or its own data security and privacy policy imposes a stricter requirement, CHSS follows the stricter requirement.

1. Purposes for which CHSS uses the data

> **State law:** 8 NYCRR § 121.3(c)(1) requires "the exclusive purposes for which the student data or teacher or principal data will be used." The TEC agreement's New York terms limit use to the services in Exhibit A. **Drafting choice:** Mirrors the draft Exhibit A on the Notes tab and Appendix A.4. The list is exhaustive on purpose: in six TEC states nothing outside it is permitted.

CHSS uses the data it receives from an LEA only for the following purposes, and for no other:

1. Calculating and displaying ninth grade on-track indicators, course performance, credits, and attendance for the school's ninth grade team, and following each ninth grade cohort's progress in later grades.
2. Operating the CHSS Navigator platform, in which school staff and CHSS coaching staff identify students needing support, plan and record interventions, and monitor progress, including software-generated intervention suggestions that educators review before use.
3. Administering the CHSS Belonging and Skills screeners, only after the LEA has approved the instruments and certified that any required parent notice or consent is in place.

4. Coaching and professional learning for the school's ninth grade team.
5. Evaluating program effectiveness using de-identified and aggregate data only.

CHSS does not sell or rent student data, does not use it for advertising or marketing, does not build profiles of students for any other purpose, and does not use it for any advocacy, lobbying, political, or fundraising activity of Stand for Children Leadership Center, Inc. or any affiliate.

2. How CHSS meets legal and contractual requirements

> **State law:** § 121.6(a)(1): the plan must "outline how the third-party contractor will implement all State, Federal, and local data security and privacy contract requirements over the life of the contract, consistent with the educational agency's data security and privacy policy." § 121.9(a)(1): contractors shall "adopt technologies, safeguards and practices that align with the NIST Cybersecurity Framework." **FERPA:** CHSS acts as a school official with a legitimate educational interest under 34 C.F.R. § 99.31(a)(1)(i)(B), under the LEA's direct control and subject to the redisclosure limits of § 99.33 (Appendix A.2). **Drafting choice:** Governance roles come from Appendix A.7 ("Responsible individuals"), added to meet California Education Code § 49073.1(b)(5); the same roles satisfy New York's expectation that the plan name who is accountable.

Legal framework. CHSS complies with the Family Educational Rights and Privacy Act; the Protection of Pupil Rights Amendment as it applies to screeners; the Children's Online Privacy Protection Act to the extent it applies; New York Education Law § 2-d and 8 NYCRR Part 121; and the student privacy laws of every other state in which an LEA it serves is located, as those laws are set out in CHSS's agreement with that LEA. For each LEA, CHSS acts as a school official under the LEA's direct control.

Contract requirements. CHSS signs the Student Data Privacy Consortium's National Data Privacy Agreement in the version adopted by the LEA's state, including multi-state versions and their state exhibits, and its own Data Privacy and Security Appendix. Where those documents differ, the stricter requirement governs. CHSS complies with each LEA's data security and privacy policy, which the LEA provides on signing.

Security framework. CHSS aligns its security program with the NIST Cybersecurity Framework. **Pending, Emily: confirm NIST CSF alignment (O20)**

Accountability. CHSS designates a Privacy Officer, **Pending, Jonah: name, title, email (O8)**, responsible for this plan and for compliance with each LEA agreement, and a Security Officer, **Pending, Emily: name, title, email**, responsible for the security program. The Privacy Officer reviews this plan at least annually and whenever CHSS's services, subprocessors, or applicable law change materially, and CHSS notifies LEAs of material changes.

3. Safeguards

> **State law:** § 121.6(a)(2): the plan must "specify the administrative, operational and technical safeguards and practices it has in place to protect personally identifiable information." The TEC agreement's New Hampshire terms list twenty-three controls, or certification under a recognized standard, as the bar. **Columbus City DSA:** Encrypted storage, U.S.-only data, salted password hashes, seven-day patching, firewall segregation, annual third-party audit, documented access with logs. **Drafting choice:** Taken from Appendix A.7 and Attachment 1. Each bullet is a present-tense claim; any that is not yet true becomes "by [date]" before publication (Decisions O4).

Administrative.

- Access to student data is limited by role to the people who need it to provide the services: the LEA's designated school staff; the CHSS coaching staff assigned to that school, for screening and intervention work only; and a small, named set of CHSS technical staff who administer the platform and investigate incidents. CHSS program and research staff see only de-identified and aggregate data.
- Every CHSS employee with access to student data passes a criminal background check before access is granted, signs a confidentiality agreement, and completes the training described in Section 5. **Pending, Demian and James: confirm current practice (O5)**
- CHSS documents every person with access, reviews the roster at least quarterly, and removes access within one business day of a change in role or separation.
- CHSS completes an independent assessment of its security controls (SOC 2 Type II or equivalent) and a penetration test of the platform at least annually. **Pending, Emily: first assessment completion date (O4)**

Technical.

- Multi-factor authentication is required for every CHSS account; LEA users may sign in through their LEA's single sign-on.
- Every access to student-level records and every administrative action is logged with user, time, and record; logs are protected from alteration, retained for at least twelve months, and available to the LEA on request.
- Production systems are segregated from the internet by firewall and network controls, deny traffic by default, and receive critical security patches within seven days of release.
- Anti-malware protection is current on every endpoint with access to student data.
- Stored passwords are salted and hashed and are never visible to CHSS staff.
- Changes to the platform go through code review and testing, and credentials are kept in a secrets vault, never in code.

Operational.

- LEAs send data by encrypted SFTP or HTTPS secure upload; email is never used to transfer student data.
- Every incoming file is virus-scanned and validated before it is loaded.
- Backups are encrypted, tested, and expire on a documented rotation of no more than ninety days; they are never restored to production except to recover from an incident.
- Software-generated intervention suggestions are recommendations for educators, who make all decisions about students. Student data, de-identified data, and outputs derived from them are not used to train, fine-tune, or improve any machine-learning model, by CHSS or any subprocessor. An LEA may ask that suggestions be turned off for its schools.

4. Where the data is stored, and encryption

> **State law:** § 121.3(c)(5): "where the student data or teacher or principal data will be stored ... and the security protections taken"; § 121.3(c)(6): "how the data will be protected using encryption while in motion and at rest." The TEC agreement's New York terms permit storage in the United States or Canada. **Columbus City DSA:** "No student data is stored outside the United States without the District's written consent." **Emily's architecture:** Microsoft Azure and Fabric for the data platform; Salesforce Experience Cloud for Navigator; Power BI for analytics.

All student data is stored and processed in data centers located in the United States, operated by the subprocessors listed in Section 6. **Pending, Emily: confirm U.S. region for each service (O14)** Data is encrypted in transit using TLS 1.2 or higher and at rest using AES-256 or equivalent, including in backups and in the file-transfer landing area.

5. Training

> **State law:** § 121.6(a)(4): the plan must specify how officers and employees "who have access to student data, or teacher or principal data receive or will receive training on the federal and state laws governing confidentiality of such data prior to receiving access." The TEC agreement's New York terms extend the requirement to subprocessors. **Drafting choice:** Appendix A.7 already commits to training "at hire and annually"; this section adds the "before access" timing New York requires.

Before receiving access to student data, and annually after that, every CHSS officer, employee, and contractor with access completes training on FERPA, the Protection of Pupil Rights Amendment, New York Education Law § 2-d and the student privacy laws of the states CHSS serves, this plan, and CHSS's incident response procedures. CHSS keeps a record of completion for each person and provides it to an LEA on request. CHSS requires each subprocessor whose personnel can access student data to train them on equivalent obligations.

6. Subprocessors

> **State law:** § 121.6(a)(5): the plan must "specify if the third-party contractor will utilize sub-contractors and how it will manage those relationships and contracts to ensure personally identifiable information is protected." § 121.3(c)(2): how the contractor ensures subcontractors abide by data protection requirements. **SDPC NDPA:** Article II.5 requires written agreements binding subprocessors to protections no less stringent than the agreement's; the TEC agreement's New York terms add that subprocessors claim no rights in the data and that CHSS must remove access, retrieve, or ensure destruction if a subprocessor fails to comply. **Drafting choice:** The table and the notice-and-remedy commitments are Appendix A.6.

CHSS uses the following subprocessors to host and process student data:

Subprocessor	Function	Location
Microsoft (Azure, Fabric)	Cloud hosting, data platform, data warehouse	United States
Salesforce (Experience Cloud, CRM Analytics)	Navigator platform, intervention records	United States
Microsoft (Power BI)	Analytics and reporting	United States

Subprocessor	Function	Location
Pending, Emily: AI model provider (O3)	File-mapping assistance, data validation, intervention suggestions	United States

Each subprocessor is bound by a written agreement that requires protections at least as strict as CHSS's own, prohibits any use of the data except to provide services to CHSS, gives it no ownership or license rights in the data, and, for the AI model provider, prohibits retaining or training on student data. CHSS reviews each subprocessor's security assurances before engaging it and annually. CHSS gives each LEA at least thirty days' notice before adding or replacing a subprocessor that will process its data. If a subprocessor fails to comply, CHSS will notify affected LEAs, remove the subprocessor's access, and retrieve the data or ensure it is destroyed.

7. Managing and reporting incidents

> **State law:** § 121.6(a)(6): the plan must specify "how the third-party contractor will manage data security and privacy incidents that implicate personally identifiable information including specifying any plans to identify breaches and unauthorized disclosures, and to promptly notify the educational agency." § 121.10 sets an outer limit of seven calendar days after discovery and requires the contractor to pay or reimburse the cost of notification for a breach attributable to it. **SDPC NDPA:** Article V.4: notice within seventy-two hours of confirmation, a written incident response plan, and the LEA notifies families; the New York terms add the number of records affected, a description of the investigation, a point of contact, and provider-paid notification costs. **Drafting choice:** Seventy-two hours satisfies the NDPA, New York, Ohio, and California. The parent-notification procedure is Appendix A.8, added to meet California Education Code § 49073.1(b)(6).

Detection. CHSS monitors access logs, administrative activity, file-transfer activity, and security alerts from its subprocessors, and investigates anomalies. Staff are trained to report any suspected incident to the Security Officer immediately.

Response. CHSS maintains a written incident response plan and tests it at least annually. For each incident CHSS assesses scope and severity, contains it, preserves evidence, recovers affected systems, documents what happened, and reviews and updates its practices.

Notice to the LEA. CHSS notifies the LEA's designated contact by telephone and email without unreasonable delay and no later than seventy-two hours after confirming any unauthorized access to, or acquisition, disclosure, or loss of, the LEA's data, whether or not it meets a statutory definition of breach, unless law enforcement requires a delay. The notice includes, as known: the nature and date of the incident, the types of data and number of records involved, the students and staff affected, the steps taken to contain it, the investigation so far, and a point of contact. CHSS updates the LEA as the investigation proceeds and cooperates with the LEA, state privacy officers, and law enforcement.

Notice to families. The LEA decides whether and how affected students, parents, and staff are notified. CHSS supplies the list of affected individuals and a draft notice, sends the notice in the LEA's name if the LEA directs it, and pays the cost of notification and related remedies for any incident attributable to CHSS or its subprocessors.

8. Return, transition, deletion, and destruction

State law: § 121.6(a)(7): the plan must "describe whether, how and when data will be returned to the educational agency, transitioned to a successor contractor, at the educational agency's option and direction, deleted or destroyed by the third-party contractor when the contract is terminated or expires." § 121.3(c)(3): the contract's duration and what happens to the data on expiration. **SDPC NDPA:** Article IV.6: disposition within sixty days of request; the TEC agreement's New York terms allow ninety days and require ninety days' notice at termination; Exhibit D is the LEA's directive form. De-identified data is exempt in every version. **Drafting choice:** Sixty days, the ninety-day backup rotation, and the officer's certificate are Appendix A.10 and Agreement 5.6; Exhibit D-4 is the form for LEAs that do not use the NDPA.

Duration. CHSS keeps an LEA's identifiable data only for the term of its agreement with that LEA. The data provisions do not renew automatically.

At the LEA's direction. At any time, on the LEA's written directive (NDPA Exhibit D, or Exhibit D-4 of CHSS's agreement), CHSS returns the specified data in a commonly used format such as CSV, transfers it to a successor the LEA names, or destroys it, within sixty days.

At termination or expiration. Within sixty days after the agreement ends, CHSS returns or destroys all of the LEA's student data, staff data, and data created in the services, including copies held by subprocessors. Copies in encrypted backups expire on the documented rotation of no more than ninety days. Destruction follows NIST SP 800-88 guidelines.

Certification. An officer of CHSS certifies destruction to the LEA in writing, listing the systems involved and the date backup copies expire. CHSS retains no identifiable data of the LEA after that date.

9. Challenging the accuracy of data

State law: § 121.3(c)(4): "if and how a parent, student, eligible student, teacher or principal may challenge the accuracy of the student data or teacher or principal data that is collected." **FERPA:** Parents and eligible students have rights to inspect, review, and seek amendment of education records (34 C.F.R. §§ 99.10–99.22), exercised through the LEA. **SDPC NDPA:** Article II.2: the provider responds within forty-five days or the state's shorter deadline. Appendix A.11 commits to ten business days.

Because CHSS receives data from the LEA's student information system, corrections are made at the source. A parent, eligible student, teacher, or principal who believes data held by CHSS is inaccurate should contact the LEA, which follows its own procedures under FERPA and state law. CHSS refers any such request it receives directly to the LEA, and within ten business days of the LEA's request provides the data it holds about the person and corrects or deletes it as the LEA directs. Corrections made in the LEA's system flow to CHSS with the next update.

10. De-identified and aggregate data

FERPA: 34 C.F.R. § 99.31(b)(1): release after a reasonable determination that a student's identity is not personally identifiable, accounting for other reasonably available information. **SDPC NDPA:** Article IV.5: de-identified use "to demonstrate the effectiveness of the Services," surviving termination; no re-identification; transfer only with written no-re-identification terms and the LEA's prior consent; the LEA approves any publication that names it. **Drafting choice:** Appendix A.10, including the documented reasonable-determination review and cell suppression below ten.

CHSS evaluates its program using de-identified and aggregate data only. It de-identifies data following NIST guidance or U.S. Department of Education guidance, replacing each student identifier with a random token not derived from any identifier, under a key CHSS destroys with the identifiable data. Before retaining or releasing de-identified data, CHSS documents its determination that no student is identifiable, considering indirect identifiers, other available information, repeated releases, and the need for complementary suppression, and makes that record available to the LEA. CHSS suppresses any aggregate cell smaller than ten students, never attempts to re-identify anyone, does not share de-identified data with any third party without the LEA's written consent and a no-re-identification agreement, and does not name an LEA in any publication without its written approval.

11. The LEA's Parents' Bill of Rights

> **State law:** § 121.6(a)(3): the plan must demonstrate compliance with § 121.3(c), the supplemental information that accompanies each LEA's Parents' Bill of Rights for Data Privacy and Security. The TEC agreement's New York terms deem the plan to incorporate the LEA's Parents' Bill of Rights, provided at Exhibit J. **Drafting choice:** The appendix below is written so each New York LEA can attach it to its Parents' Bill of Rights as CHSS's supplemental information without editing.

CHSS complies with the Parents' Bill of Rights for Data Privacy and Security of each New York LEA it serves, which is incorporated into this plan for that LEA. CHSS's supplemental information for each LEA's Parents' Bill of Rights appears below.

Required information (8 NYCRR § 121.3(c))	CHSS
Exclusive purposes for which the data will be used	Section 1 of this plan
How subcontractors and others who receive the data will abide by data protection requirements	Section 6
Duration of the agreement, and what happens to the data when it expires	Section 8; term stated in the LEA's agreement
How a parent, student, eligible student, teacher, or principal may challenge the accuracy of the data	Section 9
Where the data is stored, and the security protections taken	Sections 3 and 4
How the data is protected using encryption in motion and at rest	Section 4

12. Contacts

> **Drafting choice:** The Privacy Officer is also the NDPA designated representative and the Exhibit D-3 contact; the mailbox receives incoming Exhibit Es.

Questions about this plan, requests from an LEA, and incident reports go to the CHSS Privacy Officer, **Pending: name, privacy@ mailbox, phone**. Security matters may also be sent to the Security Officer, **Pending: name and email**.